

Fase 0 — Pre-flight (dejar base lista)

- ☐ Guardar en sesión al logear: `id_usuario`, `nombre_usuario`, `rol`, `id_direccion`.
- ☐ Crear `includes/auth.php` con:
 - `requireAuth()`, `requireAdmin()`, `requireEditorOrAdmin()`, `requireDireccion($id_dir)`
 - `ensureCsrfToken()`, `verifyCsrfOrDie()`
- ☐ Proteger rutas:
 - Admin: `admin/*` sensibles con `requireAdmin()`
 - Usuario/editor: `usuario/*` con `requireEditorOrAdmin()` y donde aplique `requireDireccion($id_dir)`

Fase 1 — Configuración por dirección (la clave de la escalabilidad)

Objetivo: un solo panel/form que se adapte según reglas de cada dirección.

1.1 Cambios en BD (agregar banderas por dirección)

sql

 Copiar  Editar

```
ALTER TABLE direcciones
ADD COLUMN permite_documentos ENUM('1','0') DEFAULT '1',
ADD COLUMN max_destacados INT DEFAULT 3,
ADD COLUMN show_all_docs ENUM('1','0') DEFAULT '0';
```

- Dir1 ahora → `permite_documentos = '0'` (por ahora no sube docs)
- Dir3 → `show_all_docs = '1'` (muestra todo; puedes ignorar "destacado" visualmente)

1.2 Helper para leer config

`includes/direcciones_config.php`

php

 Copiar  Editar

```
<?php
function getConfigDireccion(mysqli $db, int $id): array {
    $st = $db->prepare("SELECT permite_documentos, max_destacados, show_all_docs
                        FROM direcciones WHERE id_direccion=?");
    $st->bind_param("i", $id);
    $st->execute();
    $res = $st->get_result()->fetch_assoc() ?:
        ['permite_documentos'=>'1', 'max_destacados'=>3, 'show_all_docs'=>'0'];
    $st->close();
    // normaliza tipos
    $res['max_destacados'] = (int)$res['max_destacados'];
    return $res;
}
```



Fase 2 — Paneles

2.1 Panel Admin (ya lo tienes)

- ☐ Botón **Usuarios** (CRUD completo, solo admin)
- ☐ Botón **Direcciones** → selector de dirección + documentos de esa dirección (modo admin)

2.2 Panel Usuario/Editor (uno solo y dinámico)

Ruta: `/usuario/panel_usuario.php`

- ☐ Leer `$_SESSION['id_direccion']` y `getConfigDireccion()`
- ☐ Si `permite_documentos='0'` → mostrar aviso “Sin gestión de documentos por ahora”
- ☐ Si `show_all_docs='1'` → listar **todos** los docs, sin límite de “destacado” (o esconder ese campo)
- ☐ Si normal → panel CRUD con reglas de “destacado” (máx. `max_destacados`)

Fase 3 — Formularios de documentos (un solo form para todos)

Un único formulario (`nuevo_documento.php` / `editar_documento.php`) que se adapta:

3.1 UI (visibilidad dinámica)

- ☐ Si `cfg.show_all_docs=='1'` (dir3):
 - Ocultar el checkbox “Destacado” (no aplica límite de 3)
- ☐ En **todas** las direcciones:
 - Radio/check “Destacado en Home” (`destacado_home`) → sigue vigente (único por dirección)

3.2 Validación en servidor (reglas de negocio)

Siempre (independientemente de la UI):

- ☐ Si `destacado_home = 1` → poner `0` a todos los demás docs de esa dirección:

```
php                                                                    Copiar Editar

$u = $db->prepare("UPDATE documentos SET destacado_home='0' WHERE id_direccion=? AND id_documento=?");
$u->bind_param("ii", $id_direccion, $id_documento_actual); $u->execute();
```

- ☐ Si `cfg.show_all_docs != '1'` y `destacado = 1` → respetar el límite:

```
php                                                                    Copiar Editar

$q = $db->prepare("SELECT COUNT(*) FROM documentos WHERE id_direccion=? AND destacado='1' AND id_documento=?");
$q->bind_param("iii", $id_direccion, $id_documento_actual, $id_documento_actual);
$q->execute(); $q->bind_result($cuantos); $q->fetch(); $q->close();
if ($cuantos >= $cfg['max_destacados']) { /* rechaza o gestiona */ }
```

Recomendación UX: Rechazar con mensaje claro (“Máximo X destacados”). Es más predecible que desmarcar otros automáticamente.

Fase 4 — Módulo Admin: Direcciones

- ☐ `admin/direcciones.php` : selector de dirección → tabla de documentos de esa dirección
 - ☐ Botón “Agregar documento” abre el **mismo formulario** (con `id_direccion` en GET/POST)
 - ☐ (Opcional) **Configurar dirección**: pantalla para editar `permite_documentos` , `max_destacados` , `show_all_docs`
-

Fase 5 — Módulo Admin: Usuarios (solo admin)

- ☐ Listado de usuarios (ya lo armaste)
- ☐ Crear/Editar usuario:
 - nombre, correo (único), rol (`admin` / `editor`), `id_direccion` (requerido si `editor`), estado, contraseña (hash)
 - Validar `correo` único
- ☐ Eliminar o **desactivar** (mejor desactivar con `estado='Inactivo'`)
- ☐ CSRF en formularios y acciones POST 

Fase 6 — Vistas públicas (front)

- ☐ **Home**: carrusel `destacado_home=1 AND estado='Activo'` (ya lo tienes)
- ☐ **Por dirección**:
 - Dir3 → mostrar **todos** los documentos (sin filtro)
 - Otras → mostrar **hasta** `max_destacados` marcados como `destacado='1'` en su sección de destacados, y el resto debajo/paginado (si aplica)

Fase 7 — Seguridad y limpieza

- ☐ En login: `password_hash()` / `password_verify()` , `session_regenerate_id(true)`
- ☐ CSRF en todos los POST
- ☐ `.htaccess` con `Options -Indexes` y bloqueo de `.env` , seeds, etc.
- ☐ Validación de archivos (si subes PDFs/imágenes)
- ☐ Roles aplicados en todas las rutas críticas
- ☐ (Después) **Refactor** para eliminar back repetido:
 - `includes/db.php` / `conexion.php`
 - `includes/query_helpers.php` (consultas compartidas)
 - `includes/layout/*` (header/footer/nav)
 - **Componentiza** listados y formularios si los repites

Fase 8 — Pruebas (checklist)

- ☐ Editor de Dir1: ve aviso "sin gestión de documentos"
- ☐ Editor de Dir3: puede crear/ver todos; el campo "destacado" no aparece
- ☐ Editor de otra dir: al marcar "destacado" **no** le permite superar `max_destacados`
- ☐ `destacado_home` : al marcar uno, **los demás** de esa dirección quedan en 0
- ☐ Admin: puede gestionar cualquier dirección/usuario
- ☐ Intento de acceder a admin/usuarios con rol editor → bloqueado
- ☐ CSRF: acción POST sin token → rechazada
- ☐ Home: carrusel solo muestra activos y respeta 1 por dirección